



UNIVERSIDAD SANTO TOMÁS SECCIONAL TUNJA

Facultad de ingeniería de sistemas

Análisis de Seguridad con OWASP ZAP: latinoamericacomparte.com

ESPACIO ACADEMICO:

Ciberseguridad Blue Team y White hat

PRESENTADO A:

Sergio Arley Puerto Moreno

AUTORES:

Arcila Pulido Julián Andrés
Bayona Garavito Juan Pablo
Galindo Rodríguez Manuel Felipe
García Niño Michael Steven
Gómez David Fernando

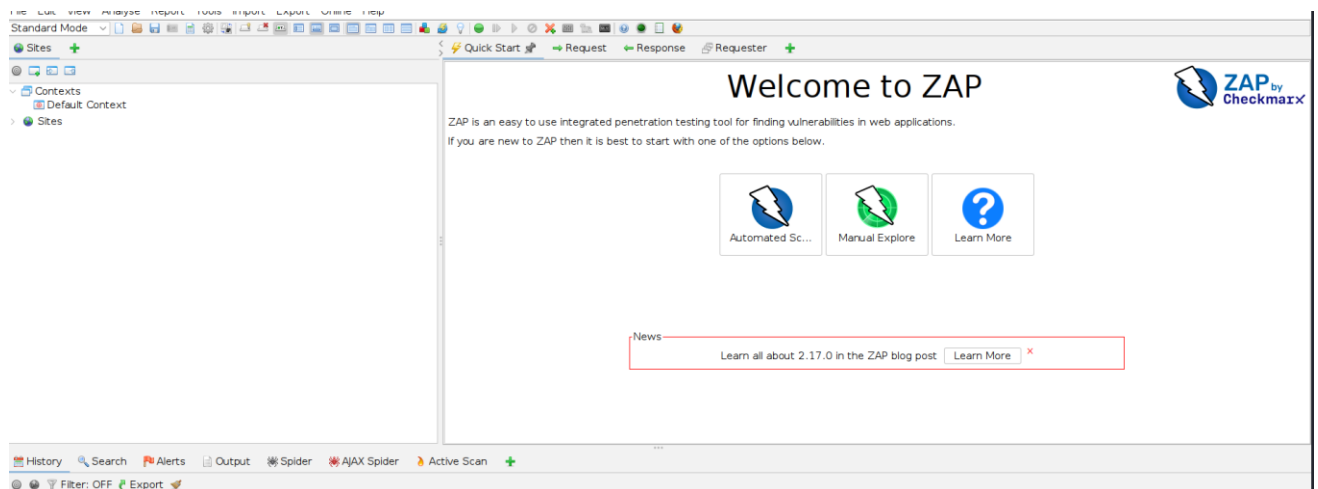
Descripción de la Herramienta

OWASP ZAP (Zed Attack Proxy) es una herramienta de código abierto para pruebas de penetración y auditorías de seguridad, mantenida por el proyecto global OWASP. Está diseñada específicamente para realizar análisis dinámico de seguridad (**DAST**) en aplicaciones web.

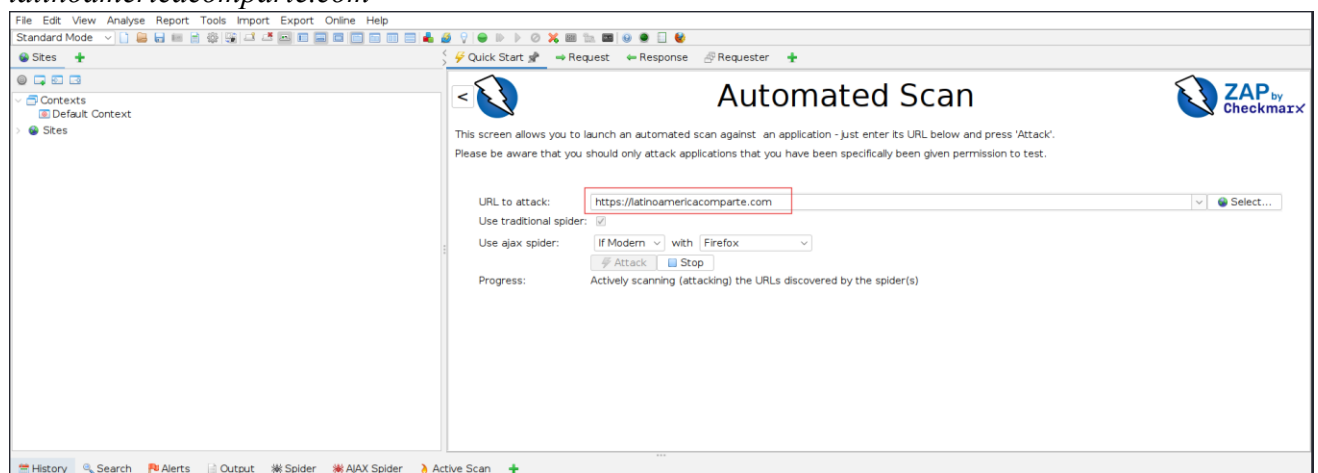
Actúa como un **proxy de interceptación** que se posiciona entre el navegador del auditor y el servidor objetivo, permitiendo rastrear, modificar y analizar todo el tráfico de red (peticiones y respuestas HTTP/HTTPS).

ZAP combina técnicas de reconocimiento pasivo y activo a través de motores automatizados (*Spiders*) para mapear la estructura de los sitios web, simulando ataques reales (como inyecciones SQL, Cross-Site Scripting y análisis de cabeceras) para identificar vulnerabilidades antes de que puedan ser explotadas por un atacante.

1. Bienvenida Herramienta

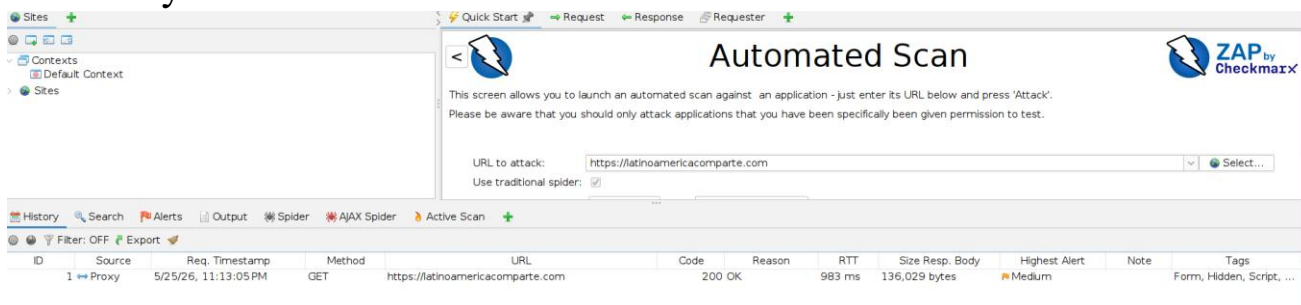


Seleccionamos Automated Scan y configuramos el sitio web al que vamos a realizar las pruebas: *latinoamericacomparte.com*



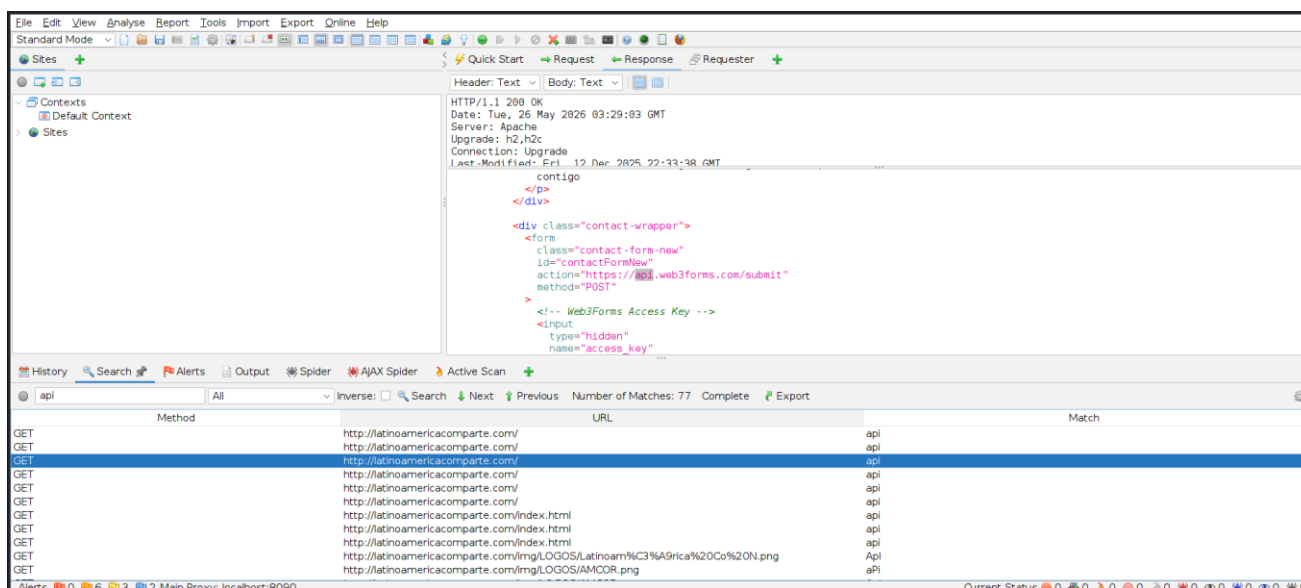
RESULTADOS

1. History



Al inicio de la auditoría, la pestaña *History* registró de forma pasiva el tráfico web inicial hacia el dominio latinoamericacomparte.com. Todas las solicitudes analizadas devolvieron exitosamente un código de estado **HTTP 200 OK**.

2. Search



Hallazgo Especial: Exposición de Claves de API en Código Fuente

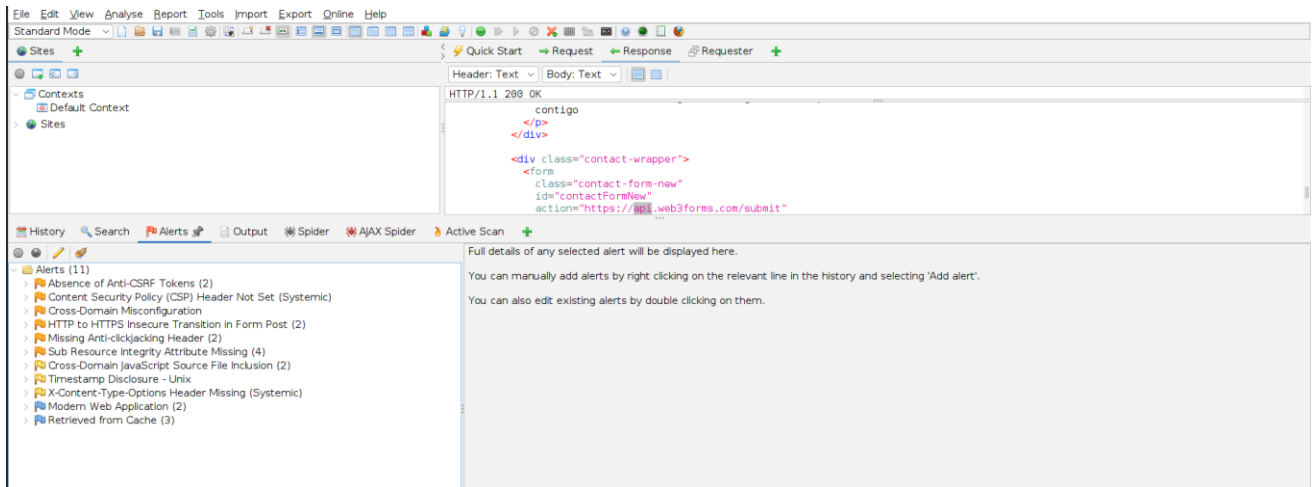
Durante la fase de inspección de datos mediante la herramienta *Search* de OWASP ZAP, se identificó que el formulario de contacto del sitio web (id="contactFormNew") expone directamente una credencial de un servicio externo:

- **Servicio:** Web3Forms API (https://api.web3forms.com/submit)
- **Dato Expuesto:** access_key con valor 7a1764d4-f138-4e7a-97e2-688c2b843930

Impacto: Esto clasifica como *Information Disclosure* (Exposición de Información). Un atacante podría recolectar esta API Key para realizar ataques de denegación de servicio sobre el formulario o suplantar los envíos de correo de la organización.

Recomendación: Se sugiere procesar los envíos de formularios a través de un backend propio o utilizar variables de entorno del lado del servidor para ocultar las llaves de servicios de terceros.

3. Alerts



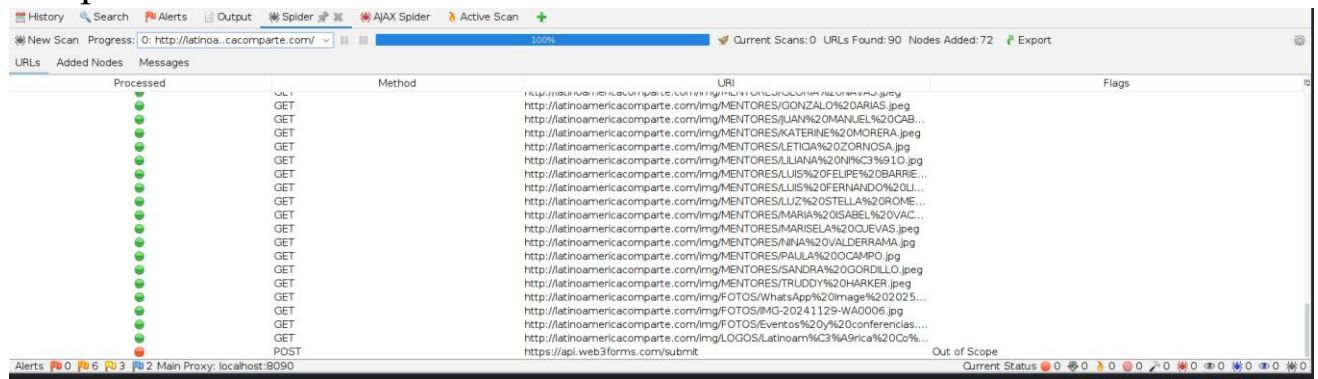
Alerts

Name	Risk Level	Number of Instances
Absence of Anti-CSRF Tokens	Medium	2
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Cross-Domain Misconfiguration	Medium	1
HTTP to HTTPS Insecure Transition in Form Post	Medium	2
Missing Anti-clickjacking Header	Medium	2
Sub Resource Integrity Attribute Missing	Medium	4
Cross-Domain JavaScript Source File Inclusion	Low	2
Timestamp Disclosure - Unix	Low	1
X-Content-Type-Options Header Missing	Low	Systemic
Modern Web Application	Informational	2
Retrieved from Cache	Informational	3

El apartado de alerts detectó un total de **11 tipos de alertas**, clasificadas entre niveles de riesgo Medio, Bajo e Informativo. No se encontraron vulnerabilidades de riesgo Alto (banderas rojas).

- **Riesgos Medios (Banderas Naranjas):** Se identificó la ausencia de tokens Anti-CSRF en los formularios y la falta de la cabecera *Content Security Policy* (CSP), lo que debilita la protección contra inyecciones de código (XSS). También se detectó una transición insegura de datos (HTTP a HTTPS) al enviar formularios y una configuración incorrecta en el acceso entre dominios (Cross-Domain).
- **Riesgos Bajos (Banderas Amarillas):** El sitio carece de las cabeceras de configuración X-Frame-Options (exponiéndolo a ataques de Clickjacking) y X-Content-Type-Options. Además, no implementa el atributo de integridad (SRI) en scripts externos, delegando la seguridad en servidores de terceros.
- **Informativas (Banderas Azules):** Se encontraron marcas de tiempo (Unix Timestamps) expuestas en el código fuente, lo que revela metadatos técnicos del servidor.

4. Spider

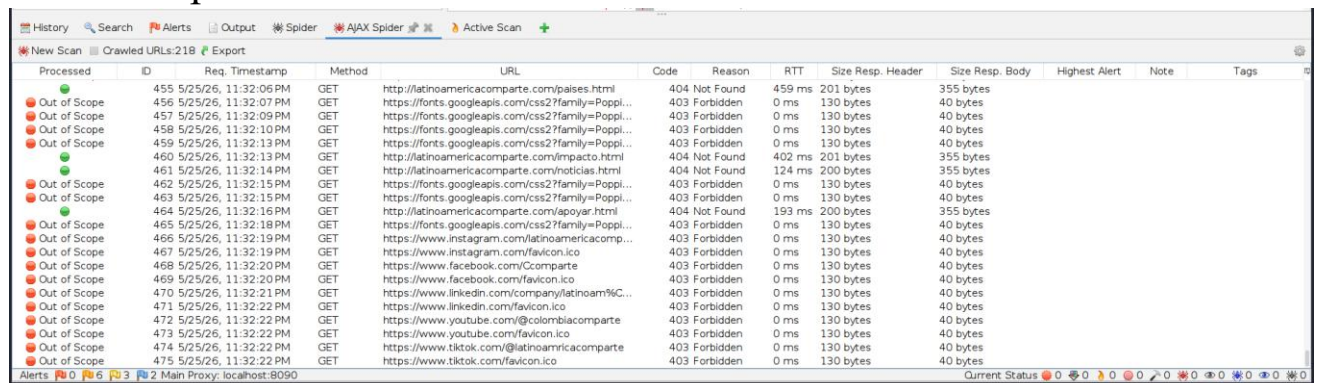


The screenshot shows the Spider tool interface with a table of processed URLs. The table has columns for Status, Method, URL, and Flags. The status column shows green circles for successful requests and red circles for 'Out of Scope' requests. The URL column lists various internal and external links from latinoamericacomparte.com.

Status	Method	URL	Flags
●	GET	http://latinoamericacomparte.com/mg/MENTORES/GONZALO%20ARIAS.jpeg	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/JUAN%20MANUEL%20CAB...	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/KATERINE%20MORERA.jpeg	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/LETICIA%20CORNOSA.jpg	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/LILIANA%20NIN%20C3%910.jpg	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/LUIS%20FELIPE%20BARRIE...	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/LUIS%20FERNANDO%20LU...	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/LUZ%20STELLA%20ROME...	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/MARIA%20ISABEL%20VAC...	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/MARISELA%20QUEJAS.jpeg	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/NIRIAN%20VALDERRAMA.jpg	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/PAULA%20OAMPO.jpg	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/SANDRA%20GORDILLO.jpeg	
●	GET	http://latinoamericacomparte.com/mg/MENTORES/TRUDDY%20HARKER.jpeg	
●	GET	http://latinoamericacomparte.com/mg/FOTOS/WhatsApp%20Image%202025...	
●	GET	http://latinoamericacomparte.com/mg/FOTOS/IMG-20241129-WA0006.jpg	
●	GET	http://latinoamericacomparte.com/mg/FOTOS/Eventos%20y%20conferencias...	
●	GET	http://latinoamericacomparte.com/mg/LOGOS/Latinoam%20C3%A9rica%20Co...	
●	POST	https://api.web3forms.com/submit	Out of Scope

Se ejecutó la herramienta Spider para descubrir la estructura del sitio web latinoamericacomparte.com, logrando identificar un total de 90 URLs y 72 nodos. Los resultados (círculos verdes) confirman el correcto mapeo de directorios internos de imágenes, recursos y archivos multimedia. Asimismo, la herramienta identificó de manera automática las peticiones dirigidas a APIs externas (círculos rojos como api.web3forms.com), marcándolas correctamente como "Fuera de Alcance" (Out of Scope) para garantizar la ética y el cumplimiento del alcance definido en la auditoría.

5. AJAX Spider



The screenshot shows the AJAX Spider tool interface with a table of crawled URLs. The table has columns for Status, ID, Req. Timestamp, Method, URL, Code, Reason, RTT, Size Resp. Header, Size Resp. Body, Highest Alert, Note, and Tags. The status column shows red circles for 'Out of Scope' requests and green circles for successful requests. The URL column lists various external and internal links.

Status	ID	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body	Highest Alert	Note	Tags
●	455	5/25/26, 11:32:06 PM	GET	http://latinoamericacomparte.com/paises.html	404	Not Found	459 ms	201 bytes	355 bytes			
●	456	5/25/26, 11:32:07 PM	GET	https://fonts.googleapis.com/css2?family=Poppi...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	457	5/25/26, 11:32:09 PM	GET	https://fonts.googleapis.com/css2?family=Poppi...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	458	5/25/26, 11:32:10 PM	GET	https://fonts.googleapis.com/css2?family=Poppi...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	459	5/25/26, 11:32:13 PM	GET	https://fonts.googleapis.com/css2?family=Poppi...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	460	5/25/26, 11:32:13 PM	GET	http://latinoamericacomparte.com/impacto.html	404	Not Found	402 ms	201 bytes	355 bytes			
●	461	5/25/26, 11:32:14 PM	GET	http://latinoamericacomparte.com/noticias.html	404	Not Found	124 ms	200 bytes	355 bytes			
●	462	5/25/26, 11:32:15 PM	GET	https://fonts.googleapis.com/css2?family=Poppi...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	463	5/25/26, 11:32:15 PM	GET	https://fonts.googleapis.com/css2?family=Poppi...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	464	5/25/26, 11:32:16 PM	GET	http://latinoamericacomparte.com/apoyar.html	404	Not Found	193 ms	200 bytes	355 bytes			
●	465	5/25/26, 11:32:18 PM	GET	https://fonts.googleapis.com/css2?family=Poppi...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	466	5/25/26, 11:32:19 PM	GET	https://www.instagram.com/latinoamericomp...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	467	5/25/26, 11:32:19 PM	GET	https://www.instagram.com/favcon.ico	403	Forbidden	0 ms	130 bytes	40 bytes			
●	468	5/25/26, 11:32:20 PM	GET	https://www.facebook.com/Comparte	403	Forbidden	0 ms	130 bytes	40 bytes			
●	469	5/25/26, 11:32:20 PM	GET	https://www.facebook.com/favcon.ico	403	Forbidden	0 ms	130 bytes	40 bytes			
●	470	5/25/26, 11:32:21 PM	GET	https://www.linkedin.com/company/latinoam%20...	403	Forbidden	0 ms	130 bytes	40 bytes			
●	471	5/25/26, 11:32:22 PM	GET	https://www.linkedin.com/favcon.ico	403	Forbidden	0 ms	130 bytes	40 bytes			
●	472	5/25/26, 11:32:22 PM	GET	https://www.youtube.com/@colombiacomparte	403	Forbidden	0 ms	130 bytes	40 bytes			
●	473	5/25/26, 11:32:22 PM	GET	https://www.youtube.com/favcon.ico	403	Forbidden	0 ms	130 bytes	40 bytes			
●	474	5/25/26, 11:32:22 PM	GET	https://www.tiktok.com/@latinoamericacomparte	403	Forbidden	0 ms	130 bytes	40 bytes			
●	475	5/25/26, 11:32:22 PM	GET	https://www.tiktok.com/favcon.ico	403	Forbidden	0 ms	130 bytes	40 bytes			

Fase de Mapeo Dinámico Avanzado (AJAX Spider) Se ejecutó el *AJAX Spider* para interactuar con los elementos dinámicos basados en JavaScript dentro de latinoamericacomparte.com, logrando rastrear un total de 218 URLs. El análisis arrojó dos hallazgos clave:

- Detección de Enlaces Rotos (Error 404):** Se descubrió que rutas críticas del menú interactivo como `/paises.html`, `/impacto.html`, `/noticias.html` y `/apoyar.html` no se encuentran disponibles en el servidor, lo que representa fallos en el despliegue de la aplicación.
- Aislamiento de Entornos Externos (Out of Scope):** La herramienta identificó e interceptó de manera segura las solicitudes hacia servicios de terceros (Google APIs, Instagram, Facebook, YouTube, TikTok), bloqueando el tráfico dinámico hacia ellos para mantener la auditoría estrictamente dentro del alcance permitido.

6. Active Scan

The screenshot shows the OWASP ZAP interface during an Active Scan. The progress bar is at 100%. The 'Sent Messages' tab is active, displaying a list of requests. The table below represents the data shown in the screenshot.

ID	Req. Timestamp	Resp. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body
637	5/25/26, 11:36:42 PM	5/25/26, 11:36:42 PM	GET	http://latinoamericacomparte.com/test.php	404	Not Found	122 ms	200 bytes	355 bytes
638	5/25/26, 11:36:42 PM	5/25/26, 11:36:42 PM	GET	http://latinoamericacomparte.com/_wpprivate/confi...	404	Not Found	124 ms	200 bytes	355 bytes
639	5/25/26, 11:36:42 PM	5/25/26, 11:36:42 PM	GET	http://latinoamericacomparte.com/_framework/blazo...	404	Not Found	123 ms	200 bytes	355 bytes
640	5/25/26, 11:36:42 PM	5/25/26, 11:36:42 PM	GET	http://latinoamericacomparte.com/.hg	404	Not Found	123 ms	200 bytes	355 bytes
641	5/25/26, 11:36:42 PM	5/25/26, 11:36:43 PM	GET	http://latinoamericacomparte.com/.bzz	404	Not Found	122 ms	200 bytes	355 bytes
642	5/25/26, 11:36:43 PM	5/25/26, 11:36:43 PM	GET	http://latinoamericacomparte.com/_darcs	404	Not Found	121 ms	200 bytes	355 bytes
643	5/25/26, 11:36:43 PM	5/25/26, 11:36:43 PM	GET	http://latinoamericacomparte.com/BtKeeper	404	Not Found	123 ms	200 bytes	355 bytes
644	5/25/26, 11:36:43 PM	5/25/26, 11:36:44 PM	GET	http://latinoamericacomparte.com/	200	OK	1.54 s	267 bytes	136,029 bytes
645	5/25/26, 11:36:44 PM	5/25/26, 11:36:45 PM	GET	http://latinoamericacomparte.com/	200	OK	832 ms	267 bytes	136,029 bytes
646	5/25/26, 11:36:45 PM	5/25/26, 11:36:46 PM	GET	http://latinoamericacomparte.com/	200	OK	714 ms	267 bytes	136,029 bytes
647	5/25/26, 11:36:46 PM	5/25/26, 11:36:47 PM	GET	http://latinoamericacomparte.com/	200	OK	596 ms	267 bytes	136,029 bytes
648	5/25/26, 11:36:47 PM	5/25/26, 11:36:47 PM	GET	http://latinoamericacomparte.com/	200	OK	476 ms	267 bytes	136,029 bytes
649	5/25/26, 11:36:47 PM	5/25/26, 11:36:47 PM	GET	http://latinoamericacomparte.com/	200	OK	360 ms	267 bytes	136,029 bytes
650	5/25/26, 11:36:47 PM	5/25/26, 11:36:48 PM	GET	http://latinoamericacomparte.com/	200	OK	357 ms	267 bytes	136,029 bytes
651	5/25/26, 11:36:48 PM	5/25/26, 11:36:48 PM	GET	http://latinoamericacomparte.com/	200	OK	357 ms	267 bytes	136,029 bytes
652	5/25/26, 11:36:48 PM	5/25/26, 11:36:48 PM	GET	http://latinoamericacomparte.com/	200	OK	358 ms	267 bytes	136,029 bytes
653	5/25/26, 11:36:48 PM	5/25/26, 11:36:49 PM	GET	http://latinoamericacomparte.com/	200	OK	242 ms	267 bytes	136,029 bytes
654	5/25/26, 11:36:49 PM	5/25/26, 11:36:49 PM	GET	http://latinoamericacomparte.com/	200	OK	245 ms	267 bytes	136,029 bytes
655	5/25/26, 11:36:49 PM	5/25/26, 11:36:49 PM	GET	http://latinoamericacomparte.com/	200	OK	245 ms	267 bytes	136,029 bytes

Se concluyó con éxito el escaneo activo automatizado al 100%, ejecutando un total de 178 peticiones de ataque dirigidas contra el servidor de latinoamericacomparte.com. Durante esta fase, la herramienta inyectó múltiples cargas maliciosas (*payloads*) e intentó realizar el descubrimiento forzado de archivos sensibles del sistema (como rutas `test.php` o directorios de control de versiones `/.hg`, `/.bzz`). El servidor respondió correctamente con códigos *404 Not Found* para las rutas inexistentes y mantuvo respuestas estables *200 OK* frente a los intentos de inyección, demostrando resistencia y estabilidad general ante vectores de ataque automatizados básicos en su página principal.

CONCLUSIONES

La auditoría de seguridad dinámica (DAST) realizada con OWASP ZAP sobre el sitio latinoamericacomparte.com determinó que la aplicación web presenta un estado de **estabilidad y resistencia óptimo frente a ataques automatizados críticos**, al no registrarse vulnerabilidades de riesgo Alto (banderas rojas) ni caídas del servidor durante la fase de escaneo activo.

Sin embargo, el análisis evidenció debilidades importantes en la configuración defensiva del servidor y en el código del lado del cliente.

Los hallazgos de **riesgo Medio y Bajo** —como la falta de cabeceras de seguridad esenciales (*Content Security Policy*, *Anti-CSRF* y *X-Frame-Options*), la presencia de enlaces rotos (errores 404 internos) y la **exposición directa de la credencial de la API de Web3Forms**— representan vectores potenciales que un atacante podría aprovechar para ejecutar suplantaciones de identidad (*Clickjacking* / *CSRF*), inyecciones de scripts (XSS) o campañas de Spam automatizado.